

SCADA Consultant Vetting Guide

How to verify credentials, evaluate OT expertise, and avoid consultants who don't understand industrial control systems

- ✓ GICSP, GRID, GCIP, and IEC 62443 certifications explained
- ✓ Step-by-step credential verification process
- ✓ 10 red flags that indicate an unqualified ICS security consultant
- ✓ Sample vetting questionnaire you can send to providers

Understanding ICS/SCADA Security Certifications

The GIAC (Global Information Assurance Certification) program — administered by SANS Institute — offers the most recognized certifications for ICS/SCADA cybersecurity professionals. Unlike generic cybersecurity certifications, these credentials specifically validate knowledge of industrial control systems, operational technology, and the unique challenges of securing environments where cyber incidents have physical consequences.

Certification Hierarchy

Level	Certification	Focus	What It Proves
Foundational	GICSP (Global Industrial Cyber Security Professional)	ICS/SCADA security essentials	Bridges IT security and OT engineering knowledge; understands industrial protocols and safety
Advanced	GRID (GIAC Response and Industrial Defense)	ICS incident response and defense	Can detect, respond to, and recover from ICS-targeted attacks
Advanced	GCIP (GIAC Critical Infrastructure Protection)	Critical infrastructure defense	Understands NERC CIP, grid security, and utility-specific threats
Expert	GIAC Advisory Board / Gold	Research-level expertise	Published research, advisory board recognition

Complementary Certifications

Certification	Issuing Body	Focus	Relevance
CISSP	ISC2	Broad cybersecurity management	Foundation credential — necessary but not sufficient for ICS work
ISA/IEC 62443 Cybersecurity Certificate	ISA (International Society of Automation)	Industrial automation security standard	Validates understanding of the dominant OT security framework
	IACRB	SCADA architecture security	SCADA-specific security architecture design

Certification	Issuing Body	Focus	Relevance
CSSA (Certified SCADA Security Architect)			
CEH (Certified Ethical Hacker)	EC-Council	General penetration testing	Useful supplement for ICS pen testing, but not OT-specific
CompTIA CASP+	CompTIA	Advanced security practitioner	Enterprise security — limited OT relevance

Full Certification Comparison

Attribute	GICSP	GRID	GCIP	CISSP
Full Name	Global Industrial Cyber Security Professional	GIAC Response and Industrial Defense	GIAC Critical Infrastructure Protection	Certified Information Systems Security Professional
Issuing Body	GIAC / SANS	GIAC / SANS	GIAC / SANS	ISC2
Associated Training	ICS410: ICS/SCADA Security Essentials	ICS515: ICS Visibility, Detection and Response	ICS456: Essentials for NERC CIP	Various
Training Cost	~\$8,500-\$9,500 (SANS course)	~\$8,500-\$9,500 (SANS course)	~\$8,500-\$9,500 (SANS course)	~\$700-\$800 (exam only)
Exam Format	115 questions, 3 hours	115 questions, 3 hours	75 questions, 2 hours	125-175 questions, 4 hours (CAT)
Passing Score	71%	63%	68%	700/1000
OT-Specific Content	100% — industrial protocols, PLCs, HMIs, safety systems	100% — ICS threat detection, incident response, forensics	100% — NERC CIP standards, utility operations	0% — general enterprise security
Renewal	36 CEUs every 4 years (\$479 maintenance fee)	36 CEUs every 4 years (\$479)	36 CEUs every 4 years (\$479)	40 CPEs/year + \$125 AMF
Market Value	\$120,000-\$200,000/yr salary; \$250-\$500/hr consulting	Premium over GICSP; IR-specific	Utility sector premium	\$130,000-\$180,000/yr; \$200-\$400/hr

GICSP is the baseline for ICS work.

If a consultant doesn't hold at least GICSP (or the ISA/IEC 62443 Certificate), they haven't demonstrated competency in industrial control system security through a standardized OT-specific exam. A CISSP alone does not qualify someone for ICS/SCADA work — it covers zero OT content.

Compliance Framework Expertise

Which Framework Does Your Consultant Need to Know?

Two-column layout

NERC CIP

- Mandatory for entities registered with NERC (utilities, ISOs, generation, transmission)
- Standards: CIP-002 through CIP-014 (BES Cyber System identification, access control, incident response, recovery, physical security, supply chain)
- Consultants must understand BES Cyber Asset categorization, Electronic Security Perimeters, and CIP evidence documentation requirements
- Enforcement: NERC can levy fines up to \$1,000,000 per violation per day

IEC 62443

- Voluntary but increasingly adopted globally across all industrial sectors
- Defines Security Levels (SL 1-4), zones and conduits model, and requirements for system integrators, asset owners, and component suppliers
- Four-part structure: General (62443-1), Policies & Procedures (62443-2), System (62443-3), Component (62443-4)
- Consultants should be able to assess your current SL-A (Achieved Security Level) against target SL-T

NIST SP 800-82 Rev. 3

- Non-mandatory but authoritative federal guidance for all OT environments
- Covers OT-specific risk management, threat landscape, security architecture, and incident response
- Aligned with NIST CSF (Cybersecurity Framework) six functions: Govern, Identify, Protect, Detect, Respond, Recover
- Widely used as the governance layer with IEC 62443 providing OT-specific engineering content

Critical

If your facility is NERC CIP-registered and you hire a consultant who doesn't understand CIP evidence standards, their assessment findings may be technically accurate but regulatorily

useless — you cannot submit them as CIP compliance evidence. Always verify CIP-specific experience for utility engagements.

How to Verify Credentials

Step-by-step verification process

Ask the consultant for their GIAC certification number and current status. All GICSP, GRID, and GCIP certifications are verifiable.

Verify through the GIAC Certified Professionals directory (giac.org/certified-professionals). Search by name to confirm active certification and certification date.

For CISSP holders, verify through the ISC2 Member Directory (member.isc2.org). CISSP status must be "Active" (not "In Good Standing" without current CPEs).

For ISA/IEC 62443 Certificate holders, request the certificate directly — ISA does not maintain a public directory. Verify the certificate number with ISA if needed.

SANS/GIAC certifications require active maintenance (36 CEUs every 4 years + \$479 renewal fee). A consultant with a GICSP from 2018 who hasn't renewed is not current on modern ICS threats. Always check the certification date and renewal status.

Verify sector-specific experience. A consultant with excellent oil and gas experience may not understand NERC CIP evidence standards for utilities. Demand references from projects in your specific sector.

Check for vendor affiliations and potential conflicts of interest. A consultant employed by or partnered with an OT monitoring vendor (Dragos, Claroty, Nozomi) may recommend their employer's product regardless of fit. Understand their vendor relationships before engagement.

10 Red Flags of an Unqualified ICS/SCADA Consultant

1 No OT-specific certifications.

Holds CISSP, CEH, or other IT security certifications but no GICSP, GRID, or ISA/IEC 62443 credential. IT security expertise does not transfer to OT environments — the protocols, architectures, and safety constraints are fundamentally different.

2 Proposes active scanning without safety review.

Plans to run Nmap or Nessus against your production SCADA network without first reviewing safety-instrumented system architecture and scheduling a maintenance window. Active scanning of fragile ICS devices (older PLCs, RTUs) can cause device crashes and process disruptions.

3 Cannot name industrial protocols.

Cannot explain Modbus TCP/RTU, DNP3, OPC UA, EtherNet/IP, or PROFINET. If the consultant's experience is limited to TCP/IP and HTTP, they don't understand OT communications.

4 Treats OT security like IT security.

Recommends standard IT solutions (aggressive patching, endpoint agents, NAC) without understanding OT constraints: systems that cannot be patched, devices that cannot run agents, and networks that must prioritize availability over confidentiality.

5 No facility/plant experience.

Has never conducted an on-site assessment in an industrial facility. OT security assessments require physical presence — network diagrams alone don't reveal air-gap violations, physical access weaknesses, or undocumented connections.

6 No safety awareness.

Cannot explain what a Safety-Instrumented System (SIS) is, why it must be isolated from the control network, or what HAZOP/SIL means. In ICS environments, cybersecurity and safety are inseparable.

7 Promises "no disruption" during active testing.

No competent ICS pen tester makes this guarantee. Active testing of OT systems always carries non-zero disruption risk. A qualified consultant acknowledges the risk and presents a mitigation plan — they don't dismiss it.

8**Delivers generic findings.**

Assessment report contains boilerplate vulnerability findings (e.g., "patch all systems") without ICS-specific context, compensating controls for unpatchable systems, or prioritization based on operational impact.

9**Cannot produce ICS-specific references.**

References are from IT security engagements, not OT/ICS assessments. Ask specifically: "Which industrial facilities have you assessed, and what was your role?"

10**Vendor-captive recommendations.**

Every recommendation points to a single vendor's product suite (their employer or partner). A credible assessment should be technology-agnostic, with recommendations based on your environment, budget, and risk profile.

When Certification Matters (Decision Matrix)

Two-column layout

REQUIRE OT-CERTIFIED (GICSP minimum, GRID/GCIP preferred) WHEN

- NERC CIP compliance assessment or audit preparation
- Active vulnerability assessment or penetration testing of ICS/SCADA systems
- Incident response for OT-targeted attacks
- IEC 62443 zone and conduit assessment
- Safety-instrumented system (SIS) security review
- OT network segmentation design
- Post-incident forensics in industrial environments
- Any engagement where consultant actions could affect physical processes

GENERAL SECURITY CONSULTANT MAY SUFFICE WHEN

- IT/OT convergence policy development (governance layer only)
- Cybersecurity awareness training for plant operators
- High-level risk assessment with no access to OT systems
- Procurement advisory for OT monitoring tools
- Even here: verify the consultant understands the IT/OT boundary and does not apply IT-centric controls to OT environments

Cost comparison

Factor	OT-Certified (GICSP/GRID)	IT-Security Only (CISSP/CEH)
Hourly rate	\$250-\$650/hr	\$150-\$350/hr
ICS protocol knowledge	Native (Modbus, DNP3, OPC UA)	None or surface-level
Safety awareness	Trained on SIS isolation, HAZOP, SIL	Not applicable
Active testing capability	Safe ICS pen testing with rollback plans	May crash production PLCs

Factor	OT-Certified (GICSP/GRID)	IT-Security Only (CISSP/CEH)
Compliance deliverables	Audit-ready (NERC CIP, IEC 62443)	Generic cybersecurity reports
Vendor independence	Varies (check affiliations)	Varies
Risk to operations	Managed — understands OT constraints	High — may apply IT playbooks to OT

Sample Vetting Questionnaire

SCADA/ICS Security Consultant Vetting Questionnaire — Send This Before Hiring

Copy and send these questions to any ICS/SCADA security consultant or firm you're considering. Their answers will tell you everything you need to know.

1. Credentials & Certification

- What ICS/OT-specific certifications do you hold (GICSP, GRID, GCIP, ISA/IEC 62443)?
- What is your GIAC certification number (if applicable)?
- Do you hold CISSP or other IT security certifications? (Note: these supplement but do not replace OT-specific credentials)
- When did you last complete your certification renewal/CE requirements?

2. ICS/OT Experience

- How many ICS/SCADA security assessments have you completed in the past 3 years?
- Which industrial sectors have you worked in (utilities, oil & gas, water, manufacturing, chemical)?
- Have you completed an assessment in our specific sector? Can you provide references?
- What industrial protocols do you have hands-on experience with (Modbus, DNP3, OPC UA, EtherNet/IP, PROFINET)?
- Describe your experience with safety-instrumented systems (SIS) and the Purdue Model.

3. Assessment Methodology

- Do you follow a specific framework (IEC 62443, NIST 800-82, NERC CIP)?
- What is your approach to active vs. passive assessment in production OT environments?
- How do you mitigate operational risk during testing?
- What tools do you use for ICS-specific vulnerability assessment?
- How do you handle findings on unpatchable legacy systems (compensating controls)?

4. Compliance & Regulatory

- Do you have experience with our applicable compliance framework (NERC CIP / IEC 62443 / TSA SD / AWIA)?
- Can your deliverables serve as compliance evidence for regulatory audits?
- Have you supported clients through a regulatory audit or enforcement action?

5. Independence & Conflicts

- Are you employed by or affiliated with an OT security monitoring vendor? If so, which one?
- Will your recommendations be technology-agnostic?
- Do you receive referral fees or commissions from any security product vendors?

6. Pricing & Logistics

- Do you offer fixed-fee assessments or time-and-materials only?
- What is your travel policy and how are travel expenses billed?
- What is included in your post-assessment support (remediation consulting, reassessment)?
- Do you carry professional liability (E&O) insurance with OT/ICS coverage? What are your policy limits?

7. References

- Can you provide 3 references from ICS/SCADA security engagements in our sector?
- Can you share a redacted assessment report from a comparable engagement?

SCADAIntel

SCADAIntel

Hire SCADA consultants you can vet.

[Browse consultants at scadaintel.com](https://scadaintel.com)